

Cross-Lingual Agent Skill Poisoning: Active Runtime Exploitation in Tool-Using LLM Agents

AUTHORS	SUPERVISOR	INSTITUTION	DATE
Al-mizan and Eva	Md. Rafsan Jani	Jahangirnagar University	September 2026

ABSTRACT

Tool-using Large Language Model (LLM) agents rely on modular skill configurations (such as `SKILL.md` specifications and Model Context Protocol servers) to dynamically discover and call tools. Because these skill definitions combine executable tool schemas with natural-language instructions, they create a semantic supply chain attack surface. Existing research focuses on English prompt injection or static pattern scanning of public registries, leaving active runtime exploitation unmeasured across low-resource languages.

This proposal presents **XLingSkillBench**, a runtime evaluation benchmark of 50 enterprise tasks paired with adversarial skills across four linguistic registers: English, high-resource (Mandarin, Spanish), low-resource (Bangla), and code-mixed (Banglish). We measure compromise progression across skill discovery, reasoning manipulation, and unauthorized tool execution on both frontier models (ChatGPT, Claude, Gemini) and open-weights models (Qwen, Llama, DeepSeek). Finally, we benchmark capability-based structural authorization against semantic intent verifiers to quantify the tradeoff between security enforcement and benign over-refusal in non-English workflows.

1. Introduction

1.1 Agentic Execution and Semantic Supply Chains

As LLMs transition from conversational chatbots to autonomous agents, model failure shifts from generating harmful text to executing unauthorized actions. Agents interpret untrusted context, select tools from external registries, and invoke APIs that modify files, query databases, or send outbound network requests (Debenedetti et al., 2024; Zhan et al., 2024).

Modular skill specifications (e.g., `SKILL.md` and MCP definitions) define operational schemas and natural-language usage guidelines. When an agent indexes an external skill, it ingests untrusted text directly into its reasoning context. An attacker who publishes a poisoned skill can embed adversarial instructions in descriptions, parameter constraints, or code examples. Without executing code directly on the host, the attacker can manipulate the agent's tool selection and trigger confused-deputy attacks (Saha et al., 2026; Qu et al., 2026).

1.2 The Cross-Lingual Vulnerability Gap

Safety alignment does not generalize uniformly across languages. Models aligned with RLHF show strong refusal behaviors on English adversarial prompts, but exhibit higher vulnerability when inputs use low-resource languages or code-mixed dialects (Deng et al., 2024; Marx, 2026).

Recent empirical scans of public skill registries found behavioral anomalies (misleading descriptions and persuasive steering) 3 to 5 times more frequently in non-English skills than in English skills (Zhang et al., 2026). However, prior studies relied on static heuristic scanners, which suffer from calibration bias on non-English text. Whether these cross-lingual skills actively compromise tool-using agents at runtime remains an open empirical question.

1.3 Research Questions

- RQ1 Runtime Exploitation Disparity:** Do malicious skill descriptions in low-resource (Bangla) or code-mixed (Banglish) registers increase the Skill Selection Rate (SSR) and Unauthorized Tool Action Rate (UTAR) compared to equivalent English payloads?
- RQ2 Model Robustness Stratification:** How do open-weights architectures (Qwen, Llama, DeepSeek) compare to frontier proprietary models (ChatGPT, Claude, Gemini) in resisting multilingual supply chain manipulation?

RQ3 Defense Invariance: Do structural authorization controls (capability tokens) and semantic intent monitors remain invariant across non-English attacks, or do semantic monitors degrade on code-mixed inputs?

RQ4 Security–Utility Tradeoff: What is the measured penalty of cross-lingual defenses on benign task completion (TSR) and false-positive over-refusal rates?

2. Related Work and Critical Gaps

2.1 Indirect Prompt Injection and Skill Poisoning

Indirect Prompt Injection (IPI) occurs when an LLM processes untrusted data during execution (Greshake et al., 2023). Benchmarks such as InjecAgent (Zhan et al., 2024) and AgentDojo (Debenedetti et al., 2024) established that LLMs frequently confuse untrusted data with privileged instructions. In the supply chain space, Skill-Inject (Schmotz et al., 2026) demonstrated high attack success rates via poisoned skill files, while Saha et al. (2026) showed that adversarial metadata grants attackers discovery advantages in `SKILL.md` registries. These evaluations remain limited to monolingual English contexts.

2.2 Cross–Lingual Safety Alignment Disparities

Safety filters degrade on non-English inputs. MultiJail (Deng et al., 2024) and recent Indic safety studies show that alignment data concentrates heavily on English. In Bangla specifically, guardrails struggle with colloquial and code-mixed phrasing while producing high false-positive rates on benign queries. In agent research, MIPIAD (2025) proposed bilingual defenses for text retrieval, but did not address tool selection, schema parsing, or execution policies.

2.3 Critical Research Gaps

- Absence of Active Runtime Exploitation:** Prior multilingual skill studies (Zhang et al., 2026) examined static metadata without testing interactive agent execution.
- Lack of Multilingual Tool Benchmarks:** Existing tool security benchmarks (AgentDojo, InjecAgent) do not support low-resource or code-mixed task suites.
- Unverified Language Invariance in Runtime Defenses:** Modern runtime monitors (e.g., VIGIL) rely on English semantic traces and have not been tested against cross-lingual evasion.

3. Threat Model

System Environment

An autonomous agent equipped with local or registry-based skill packages, standard utilities (file reading, web searching), and system tools (command execution, file writing, external network requests).

Attacker Capabilities

An external adversary who publishes or updates a third-party skill specification (`SKILL.md` or MCP tool metadata). The attacker cannot access base system prompts, model weights, or agent runtime memory, and cannot run arbitrary code on the host without the agent explicitly calling the tool.

Attacker Objective

Induce unauthorized tool invocations (such as exfiltrating environment credentials or modifying sensitive configurations) when the agent processes a benign user query.

Assumptions

The agent dynamically parses natural-language skill descriptions to select and execute tools. The user prompt itself is benign.

4. Compute Feasibility & Budget Analysis

- Local Inference Compute:** Open-weights models (Qwen, Llama, DeepSeek) will be evaluated using vLLM or 4-bit/8-bit quantization on single-GPU hardware (16GB–24GB VRAM via university lab workstations or Google Colab Pro). No model pretraining or full fine-tuning is required.
- API Budget:** Frontier model evaluations (ChatGPT, Claude, Gemini) require totaling under \$50 USD.
- Open Source Artifacts:** All benchmark tasks, poisoned skills, evaluation harnesses, and trace logs will be released under an open-source license.

5. Verified References

1. Atil, B. (2025). Do Methods to Jailbreak and Defend LLMs Generalize Across Languages? *arXiv preprint arXiv:2511.00689*.
2. Debenedetti, E., Zhang, J., Balunović, M., Beurer-Kellner, L., Fischer, M., & Vechev, M. (2024). AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents. *Thirty-eighth Conference on Neural Information Processing Systems (NeurIPS 2024) Datasets and Benchmarks Track*. DOI: [10.52202/079017-2636](https://doi.org/10.52202/079017-2636).
3. Deng, Y., Zhang, W., Pan, S. J., & Bing, L. (2024). Multilingual Jailbreak Challenges in Large Language Models. *International Conference on Learning Representations (ICLR 2024)*. arXiv:2310.06474.
4. Evtimov, I., et al. (2025). WASP: Benchmarking Web Agent Security Against Prompt Injection Attacks. *arXiv preprint arXiv:2504.18575*.
5. Greshake, K., Abdelnabi, S., Mishra, S., Endres, C., Holz, T., & Fritz, M. (2023). Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection. *Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security (AISEC)*. DOI: [10.1145/3605764.3623985](https://doi.org/10.1145/3605764.3623985).
6. Huang, C., Huang, X., Tran, N. P., & Fard, A. M. (2026). Model Context Protocol Threat Modeling and Analyzing Vulnerabilities to Prompt Injection with Tool Poisoning. *arXiv preprint arXiv:2603.22489*.
7. Ji, Z., Wu, D., & Jiang, W. (2026). Taming Various Privilege Escalation in LLM-Based Agent Systems: A Mandatory Access Control Framework. *arXiv preprint arXiv:2601.11893*. DOI: [10.48550/arxiv.2601.11893](https://doi.org/10.48550/arxiv.2601.11893).
8. Jia, X., Liao, J., Qin, S., Gu, J., & Ren, W. (2026). SkillJect: Effectively Automating Skill-Based Prompt Injection for Skill-Enabled Agents. *arXiv preprint arXiv:2602.14211*.
9. Li, Y., Chen, Y., Wen, H., Zhang, B., Liu, H., Wang, P., Feng, Y., & Tian, Y. (2026). VIGIL: Runtime Enforcement of Behavioral Specifications in AI Agent Skills. *arXiv preprint arXiv:2606.26524*.
10. Liu, Y., Chen, Z., Zhang, Y., Deng, G., Li, Y., Ning, J., et al. (2026). 'Do Not Mention This to the User': Detecting and Understanding Malicious Agent Skills in the Wild. *arXiv preprint arXiv:2601.10338*.
11. Marx, D. (2026). Multilingual Jailbreaking of LLMs Using Low-Resource Languages. *arXiv preprint arXiv:2605.18239*.
12. Qu, Y., & Liu, Y. (2026). Supply-Chain Poisoning Attacks Against LLM Coding Agent Skill Ecosystems. *arXiv preprint arXiv:2604.03081*.
13. Saha, S., Faghih, K., & Feizi, S. (2026). Under the Hood of SKILL.md: Semantic Supply-chain Attacks on AI Agent Skill Registry. *arXiv preprint arXiv:2605.11418*.
14. Schmotz, D., Beurer-Kellner, L., Abdelnabi, S., & Andriushchenko, M. (2026). Skill-Inject: Measuring Agent Vulnerability to Skill File Attacks. *arXiv preprint arXiv:2602.20156*.
15. Zhan, Q., Liang, Z., Ying, Z., & Kang, D. (2024). InjecAgent: Benchmarking Indirect Prompt Injections in Tool-Integrated Large Language Model Agents. *Findings of the Association for Computational Linguistics: ACL 2024*. DOI: [10.18653/v1/2024.findings-acl.624](https://doi.org/10.18653/v1/2024.findings-acl.624).
16. Zhang, H., Huang, J., Mei, K., et al. (2025). Agent Security Bench (ASB): Formalizing and Benchmarking Attacks and Defenses in LLM-based Agents. *International Conference on Learning Representations (ICLR 2025)*. DOI: [10.48550/arxiv.2410.02644](https://doi.org/10.48550/arxiv.2410.02644).
17. Zhang, J., et al. (2026). Do Agent Skills Speak Safety in Every Language? A Cross-Lingual Security Analysis of the Skills Ecosystem. *AgentSkills Workshop, ACM Conference on Conversational and Agentic AI Systems (CAIS 2026)*.
18. Zhao, L., Bhaskar, A., & Dobriban, E. (2026). LivePI: More Realistic Benchmarking of Agents Against Indirect Prompt Injection. *arXiv preprint arXiv:2605.17986*.